Security Architecture: Sensitive Data Encryption

This document describes the technical implementation of the security measures used for storing and searching sensitive data (Uruguayan National Identity Cards), ensuring confidentiality and integrity.

1. Overview

The system adopts a defense-in-depth approach, separating data **viewing** capabilities from **search** capabilities through two distinct mechanisms.

2. Security Components

> **Confidentiality (AES-GCM):** Sensitive data is encrypted using the AES-GCM (Advanced Encryption Standard - Galois/Counter Mode) algorithm. This method ensures both encryption and data integrity authentication, making decryption impossible without the correct key.

> **Secure Search (Blind Index / HMAC-SHA256):** To enable searches without decrypting the database, we use a "Blind Index". The identity card number is transformed into an HMAC-SHA256 hash. This process is one-way and irreversible.

3. The Security Differentiator: Global Salt

To enhance security, we apply a **Global Salt** stored exclusively in the Cloudflare *Secret Storage*. By combining the identity card number with this salt before hashing, we ensure that:

- Dictionary attacks or *Rainbow Tables* are ineffective, as the global salt is unknown to the attacker.
- The database does not contain readable data, only static hashes.

- Even if an attacker gains access to the database, the absence of keys within the Worker makes user re-identification impossible.

4. Isolation Summary

The architecture is designed so that no single component has full access to the data:

- **Database:** Stores only hashes (blind indexes) and encrypted data.
- **Cloudflare Worker:** Holds the cryptographic keys (AES and HMAC) and the Global Salt.
- **Application (Server):** Manages the flow without ever having direct access to cryptographic secrets.